

3.1 Implementation Overview

The implementation of the Multi-Factor Authentication (MFA) solution at FinSecure Pvt. Ltd. will follow a structured and phased approach to ensure minimal disruption to business operations while achieving comprehensive security coverage.

Given the organization's **400-user base**, hybrid IT environment, and limited IT team (8 members), the implementation strategy is designed to be:

- **Incremental** (phased deployment)
- **Low-risk** (pilot-first approach)
- **User-friendly** (gradual adoption)
- **Scalable** (future-ready architecture)

The implementation will prioritize high-risk systems and users first, followed by organization-wide enforcement.

The overall implementation is expected to be completed within approximately 6–8 weeks, depending on system integration complexity and user adoption rates.

3.2 Pilot Testing Plan

A pilot phase will be conducted to validate the MFA solution in a controlled environment before full deployment.

3.2.1 Pilot Scope

- Users: IT team (8 users) + selected admin accounts
- Systems:
 - VPN access
 - Microsoft 365 login
 - One internal application (HR or loan system)

3.2.2 Objectives

- Validate MFA functionality across systems
- Identify integration issues
- Evaluate user experience
- Test fallback and recovery mechanisms

3.2.3 Success Criteria

- Successful MFA login across all pilot systems
- No critical authentication failures
- Positive user feedback
- Stable system performance

3.3 Phased Rollout Strategy

Following a successful pilot, MFA will be deployed in phases:

Phase	Duration
Pilot	1–2 weeks
Phase 1	1 week
Phase 2	2 weeks
Phase 3	3–4 weeks
Optimization	Ongoing

3.3.1 Phase 1: Critical Accounts

- Users:
 - Admin accounts
 - IT team
- Systems:
 - VPN
 - Microsoft 365 (admin access)

Objective: Secure highest-risk access points first

3.3.2 Phase 2: High-Risk Business Units

- Users:
 - Finance team
 - HR team
- Systems:
 - Internal applications
 - Email access

Objective: Protect sensitive business data

3.3.3 Phase 3: Organization-Wide Deployment

- Users:
 - All remaining employees (~400 users)
- Systems:
 - All integrated platforms

Objective: Achieve full MFA coverage

3.3.4 Phase 4: Optimization & Enforcement

Objective: Harden MFA policies, eliminate exceptions, and ensure long-term operational effectiveness.

Duration: Ongoing from week 7 onwards

3.3.4.1 Policy Enforcement Actions

Action	How	Owner
Remove all temporary bypasses	Audit Entra ID for active TAPs and exceptions, revoke any still active beyond approved window	IT lead
Enforce block-legacy-authentication policy	Enable Conditional Access rule blocking basic auth protocols (SMTP, IMAP, POP3)	IT administrator
Enable MFA registration campaign	Force remaining unenrolled users to complete enrollment at next login	IT administrator
Review and tighten session lifetimes	Reduce token lifetime for high-risk roles via Entra ID token configuration	IT lead

3.3.4.2 Conditional Access Fine-Tuning

After full deployment, Conditional Access policies will be reviewed against real sign-in data:

- Pull sign-in logs from Entra ID for the first 30 days post-deployment
- Identify false positives — legitimate users being incorrectly flagged as high-risk
- Adjust location-based policies if remote workers in Pune and Bengaluru are being consistently challenged unnecessarily
- Review MFA prompt frequency — if users are being challenged more than once per session on the same device, session persistence settings need adjustment
- Validate number matching is active on all push notification policies

3.3.4.3 Account Hygiene Actions

Based on the identity audit findings in Document 1:

- Disable all orphaned accounts identified in Table 2 (~20 accounts)
- Rotate credentials on all service accounts and enforce MFA where technically feasible
- Remove shared admin credentials — assign individual accounts to each IT team member with personal FIDO2 tokens
- Review contractor accounts — enforce expiry dates and remove accounts inactive for 30+ days

3.3.4.4 Monitoring Calibration

- Review Microsoft Sentinel alert thresholds — reduce false positive alerts from brute-force detection rules
- Confirm all detection use cases from Document 5 section 5.4 are actively firing
- Schedule first monthly authentication report — login success rates, MFA method distribution, failed attempt trends
- Set quarterly review cadence for Conditional Access policies going forward

3.3.4.5 Success Metrics

The optimization phase is considered complete when:

Metric	Target
MFA enrollment rate	100% of active users
Authentication success rate	≥ 95% on first attempt
Temporary bypasses active	0
Orphaned accounts	0
Legacy authentication blocked	100%
Monthly auth report produced	Yes

3.3.5 Rollback Plan

Despite careful planning, deployment issues may arise that require partial or full rollback of MFA enforcement. This section defines the rollback procedure for each phase.

3.3.5.1 Rollback Triggers

A rollback is initiated if any of the following occur during a deployment phase:

- Critical authentication failures preventing legitimate users from accessing systems
- VPN or remote access becoming inaccessible to a significant number of users
- Application integration failures causing business operations to stop
- Unexpected account lockouts affecting more than 5% of enrolled users

3.3.5.2 Rollback Procedure

Phase	Rollback Action	Responsible	Time to Execute
Pilot	Disable MFA enforcement in Entra ID for pilot group	IT lead	< 15 minutes
Phase 1	Revert Conditional Access policy to report-only mode	IT administrator	< 20 minutes
Phase 2	Remove MFA requirement for affected department group	IT administrator	< 20 minutes
Phase 3	Revert org-wide policy, restore previous auth settings	IT lead + senior admin	< 30 minutes

3.3.5.3 Report-Only Mode

Before enforcing any Conditional Access policy, it must first be run in report-only mode for a minimum of 48 hours. This allows the IT team to observe which users would be affected without actually blocking access. No phase proceeds to enforcement without a report-only validation period.

3.3.5.4 Post-Rollback Actions

After any rollback:

1. Document the failure — what failed, when, how many users affected
2. Identify root cause before rescheduling deployment
3. Update the implementation plan to address the identified issue
4. Notify management if a phase is delayed by more than one week
5. Reschedule the phase with additional safeguards in place

3.3.5.5 Checkpoint Rule

No phase begins until the previous phase has been stable for a minimum of 5 business days with zero critical incidents. This ensures issues from one phase do not compound into the next.

3.4 User Enrollment Plan

User enrollment will be conducted in a structured and guided manner to ensure smooth adoption.

3.4.1 Enrollment Steps

1. User receives enrollment notification
 2. User registers MFA method:
 - Authenticator app (primary)
 - Backup method (SMS/email)
 3. User completes verification
 4. Enrollment confirmation
-

3.4.2 Enrollment Strategy

- Staggered enrollment based on rollout phases
 - Self-service with IT support available
 - Mandatory completion before enforcement
-

3.4.3 Fallback & Recovery

- Backup authentication methods
 - Temporary bypass (with approval)
 - IT-assisted re-enrollment
-

3.5 Communication Strategy

Effective communication is critical for successful MFA adoption.

3.5.1 Pre-Implementation

- Announcement emails explaining:
 - Why MFA is being implemented
 - Benefits for users and organization
 - Clear timelines and expectations
-

3.5.2 During Implementation

- Step-by-step guides
 - Video tutorials (optional)
 - Helpdesk support
-

3.5.3 Post-Implementation

- Reminders for best practices
 - Awareness about phishing and MFA fatigue
 - Feedback collection
-

3.6 Testing & Validation

Comprehensive testing will be conducted throughout implementation.

3.6.1 Functional Testing

- MFA login across:
 - VPN
 - Microsoft 365
 - Internal applications
-

3.6.2 Integration Testing

- Active Directory integration
 - SSO functionality
 - VPN authentication flow
-

3.6.3 Security Testing

- Simulated:
 - Brute-force attempts
 - Unauthorized login attempts
 - Verification of MFA enforcement
-

3.6.4 User Acceptance Testing (UAT)

- Feedback from pilot users
 - Ease of use evaluation
 - Issue identification
-

3.6.5 Validation Outcomes

- MFA working across all systems
 - No critical failures
 - Improved authentication security
-

3.7 Resource Allocation

3.7.1 Overview

Given FinSecure's IT team of 8 members and no dedicated security team, clear ownership of each implementation phase is critical to avoid bottlenecks and ensure accountability throughout the rollout.

3.7.2 Role Definitions

Role	Responsibility Scope
IT Lead	Overall project ownership, escalation point, management reporting
Senior IT Administrator	Entra ID configuration, Conditional Access policies, Azure AD Connect
IT Administrator A	VPN / RADIUS / NPS setup and testing
IT Administrator B	Microsoft 365 integration, SSO configuration
IT Administrator C	Endpoint management, Intune, Windows Hello for Business
Helpdesk (x2)	User enrollment support, TAP issuance, first-line MFA issues
IT Generalist	Communication, training coordination, documentation

3.7.3 Phase Ownership Matrix

Phase	IT Lead	Sr. Admin	Admin A	Admin B	Admin C	Helpdesk	Generalist
Pilot	Oversees	Configures Entra ID	Tests VPN	Tests M365	Tests endpoints	Supports IT team	Documents findings
Phase 1 — Critical accounts	Approves	Enforces CA policies	VPN MFA enforcement	Admin M365 MFA	Device compliance	Assists admin enrollment	Sends comms
Phase 2 — Finance & HR	Monitors	Adjusts policies	—	SSO for internal apps	Intune compliance	Enrolls Finance & HR	Training sessions
Phase 3 — Org-wide	Monitors	Policy finalisation	—	App integrations	Endpoint rollout	Bulk enrollment support	Awareness campaign
Optimization	Reviews	Fine-tunes policies	VPN log review	Token/session config	Device audit	TAP cleanup	Monthly report

3.7.4 Escalation Path

If any team member encounters a blocking issue during their phase:

1. Raise with IT Lead immediately — do not attempt workarounds independently
2. IT Lead assesses whether a rollback trigger has been met (refer to section 3.3.5)
3. If unresolved within 4 hours, IT Lead escalates to management and documents the issue
4. Microsoft support can be engaged for Entra ID or Azure AD Connect issues via the Microsoft 365 admin portal

3.7.5 External Dependencies

Dependency	Owner	Notes
Microsoft 365 tenant access	IT Lead	Required for Entra ID configuration
Azure MFA NPS Extension	Admin A	Download from Microsoft, requires server access
YubiKey hardware tokens	IT Lead	Procurement required before Phase 1 begins
Intune device enrolment	Admin C	Devices must be enrolled before biometrics can be enforced
User phone numbers / emails	Helpdesk	Must be verified before SMS / email OTP can be enabled

3.7.6 Estimated Effort per Phase

Phase	Duration	Estimated IT Hours
Pilot	1–2 weeks	~24 hours
Phase 1	1 week	~16 hours
Phase 2	2 weeks	~30 hours
Phase 3	3–4 weeks	~48 hours
Optimization	Ongoing	~8 hours/month

Total estimated implementation effort: **~118 hours** across 6–8 weeks, distributed across 8 team members — approximately 15 hours per person, manageable alongside regular IT operations.
